



VULNERABILITY MANAGEMENT

Vulnerability & Patch Management Policy

Subprocessor-managed patching for cloud platforms;
founder-managed patching for laptops; WeCon firmware per
vendor advisory.

Masar Zero does not operate its own vulnerability scanner or commission its own
penetration test. Subprocessor platforms (WorkOS, Vercel, Supabase) operate their own
vulnerability management programs as part of their SOC 2 attestation. Founder laptops
auto-update OS and browsers. WeCon firmware is patched per vendor advisory.

PREPARED BY	Masar Zero W.L.L.
DOCUMENT ID	MZ-POL-005
VERSION	v1.0
EFFECTIVE	12 July 2026
CLASSIFICATION	Internal Use — Authorized Recipients Only

Document Control

Document ID	MZ-POL-005	Version	v1.0
Effective Date	12 July 2026	Review Cycle	Annual (next review: July 2027)
Document Owner	Hari Krishna	Classification	Internal Use
Publisher	Masar Zero W.L.L.	Contact	hari@masarzero.com

Revision History

Version	Date	Author	Summary of Change
v1.0	12 July 2026	Masar Zero	Initial release of Vulnerability & Patch Management Policy.

Approval

This document is prepared by Hari Krishna and approved by Dr. A. Latif Alkhaja, Chairman of Masar Zero W.L.L. It is effective as of the date shown above and is reviewed annually or upon significant change per MZ-POL-001 §7. Distribution is restricted to authorized recipients; redistribution requires written approval from Masar Zero leadership.

Role	Name	Signature	Date
Prepared by	Hari Krishna		
Approved by	Dr. A. Latif Alkhaja (Chairman)		

1. Purpose & Scope

This policy defines the controls Masar Zero W.L.L. applies to identify, prioritize, and remediate vulnerabilities in its technology assets. It applies to all Masar Zero cloud resources (hosted on subprocessor platforms), the WeCon box at customer stations, and Masar Zero founder laptops.

Honest scope statement. Masar Zero is a small startup. We do not operate our own vulnerability scanner, run weekly scans, or commission an annual independent penetration test. We rely on: (a) subprocessor platform vulnerability management (WorkOS, Vercel, Supabase each operate their own programs as part of SOC 2); (b) founder laptop auto-update (macOS/Windows built-in); (c) GitHub Dependabot for the small Next.js dashboard codebase; (d) WeCon firmware advisories for the PLC.

2. Asset Inventory

Vulnerability management requires an accurate asset inventory. The Masar Zero asset register is maintained by founders in a Google Sheet. It is the source of truth for what is patched and what is excluded.

Asset Class	Examples	Inventory Location
Cloud application	Masar Zero dashboard (Next.js on Vercel)	Vercel project dashboard
Cloud database	Supabase Postgres instance	Supabase project dashboard
Plant floor	WeCon V-Net box, router	Google Sheet asset register
Endpoint	Masar Zero founder laptops	Google Sheet asset register
Third-party code	npm packages for dashboard	package-lock.json (GitHub)

Table 1 — Asset classes and inventory sources.

3. Vulnerability Discovery

Vulnerabilities are discovered through four mechanisms, three of which are operated by subprocessors:

- **Subprocessor platform vulnerability management (WorkOS, Vercel, Supabase):** Each subprocessor operates its own vulnerability scanning and remediation as part of their SOC 2 attestation. Masar Zero relies on their programs and does not run its own scans against their platforms.
- **GitHub Dependabot for dashboard codebase:** Dependabot opens PRs for vulnerable npm dependencies in the Masar Zero dashboard repository. Founders review and merge these PRs within 7 days for high-severity alerts, 30 days for medium.
- **Founder laptop auto-update:** macOS and Windows laptops auto-install OS and browser security updates within 72 hours of release.
- **WeCon firmware advisories:** Founders monitor WeCon firmware advisory announcements (via WeCon vendor communication) and apply firmware updates within 30 days of advisory release.

4. Patch Management

Patch deployment is governed by severity-based targets. Masar Zero does not operate its own patch management infrastructure; patches are applied through subprocessor platform mechanisms or founder laptop auto-update.

Asset	Patch Mechanism	Owner	Target SLA
Vercel platform runtime	Vercel auto-managed	Vercel (subprocessor)	Automatic
Supabase Postgres	Supabase auto-managed	Supabase (subprocessor)	Automatic
WorkOS platform	WorkOS auto-managed	WorkOS (subprocessor)	Automatic
Masar Zero dashboard dependencies	GitHub Dependabot PR → founder review	Founders	High: 7 days; Medium: 30 days; Low: next release
Founder laptops (OS, browser)	macOS/Windows auto-update	Founders	Within 72 hours of release
WeCon box firmware	Manual update via WeCon cloud console	Founders	Within 30 days of advisory
Station-side router firmware	Manual update by founder on site visit	Founders	Within 30 days of advisory

Table 2 — Patch management by asset.

5. Independent Penetration Testing

Masar Zero does not commission its own penetration test. Masar Zero is a small startup and the cost of an annual independent penetration test is not proportionate to the risk profile. Instead, Masar Zero relies on the penetration tests commissioned by each subprocessor as part of their SOC 2 Type II attestation:

- WorkOS penetration testing — <https://workos.com/security>
- Vercel penetration testing — <https://vercel.com/security>
- Supabase penetration testing — <https://supabase.com/security>
- Google Workspace penetration testing — <https://workspace.google.com/security/>
- GitHub penetration testing — <https://github.com/security>

If a customer requires an independent penetration test of the Masar Zero deployment as a condition of contract, Masar Zero will engage a CREST-certified firm at the customer's expense and share the report under NDA.

6. Exceptions & Compensating Controls

Where a patch cannot be deployed within the target SLA (e.g., WeCon firmware update requires a station visit), a founder documents the exception in a Google Sheet, notes the compensating controls in place (e.g., air-gap, external Wi-Fi only), and sets a target remediation date. Exceptions are reviewed at the annual program review.

7. References

- MZ-POL-001 — Governance Program
- MZ-POL-009 — Secure Software Development Practices (covers dashboard dependency scanning)
- WorkOS Security — <https://workos.com/security>
- Vercel Security — <https://vercel.com/security>
- Supabase Security — <https://supabase.com/security>
- GitHub Dependabot — <https://docs.github.com/en/code-security/dependabot>

MZ-POL-005 — Vulnerability & Patch Management Policy. End of document.